

【제 목】 : DBMS1) 관리자용 계정 관리 부적절(권고)

【내 용】

- 정보통신실은 정보통신시스템을 안정적으로 유지·관리하기 위하여 서버, 네트워크, DB 등의 정보자원을 운영·관리하고 있고, 각종 서버에는 전 국민 진료정보, 수가 및 약가 정보, 임직원 개인 정보 등 63개의 시스템에 약 6만개의 테이블을 보유하고 있다.
- 해당 DB에 접속하기 위해서는 「정보보안지침」 제73조에 따라 개별 사용자별로 계정 권한을 부여받아 업무를 하되, 업무상으로 관리자 계정이 필요한 경우에는 그룹별 접근 권한을 부여받아 사용하여야 한다고 규정되어 있다.

☞ 참고자료 【정보보안지침】

제51조(서버 보안)

① 원장은 서버를 도입·운용하고자 할 경우 사이버공격으로 인한 자료 절취 및 위·변조 등에 대비하여 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 서버 내 저장자료에 대하여 업무별·자료별 중요도에 따라 개별사용자의 접근권한 차등 부여
2. 개별사용자별 자료 접근범위를 서버에 등록하여 인가여부를 식별하도록 하고 인가된 범위 이외 자료 접근통제

(이하 생략)

제73조(계정 관리)

① 원장은 개별사용자에게 소관 정보통신망 또는 공용(公用) 정보시스템의 접속에 필요한 사용자 계정(아이디)을 부여하고자 할 경우 다음 각 호에 해당하는 사항을 준수하여야 한다.

1. 개별사용자별 또는 그룹별 접근권한 부여
2. 외부인에게 계정을 부여하지 아니하되 업무상 불가피한 경우 원장 책임 하에 보안조치 후 필요한 업무에 한하여 일정기간 동안 접속 허용
3. 특별한 사유가 없는 한 용역업체 인원에게 관리자 계정 부여 금지
4. 비밀번호 등 식별 및 인증 수단이 없는 사용자 계정은 사용 금지

② ~ ⑤ (생략)

- 이에, 감사일 현재(2020년 4월) 관리자 계정으로 DB에 접속한 로그를 확인한 결과,

1) DBMS(Database management system, 데이터베이스관리시스템) : DB 형태로 저장된 방대한 양의 각종 정보를 체계적으로 관리하는 기업용 소프트웨어

- 【표】 '개인 계정과 관리자 계정 보유 현황'과 같이 총 32명이 개인계정이 있음에도 불구하고 관리자계정으로 업무를 수행하였으며, 특히 '차세대 심사운영시스템'의 'APP_RV' 관리자계정은 10명의 직원이 사용하여 DB에 접속한 것을 확인하였다.
 - 동일한 관리자 계정을 다수가 사용할 경우, 임의로 데이터를 변경하거나 비표준화된 임시 테이블을 생성할 수 있고, 인가되지 않은 사용자가 고유식별정보도 열람이 가능하여 개인정보 오남용 조회 등의 보안 사고가 발생할 수 있다.
- 따라서, 개인 계정으로 DB 접속 업무를 수행하되, 업무상으로 관리자 계정이 필요한 경우 별도의 승인 절차를 받아 보안 사고를 예방하기 위한 정보보안 방안 마련이 필요하다.

【표】 개인 계정과 관리자 계정 보유 현황

연번	정보통신시스템	소속	성명	개인계정	관리자계정
1	기관운영	◆실 ◆부	○○○	*****	*****
2	기관운영	■실 ■부	○○○	*****	*****
3	기관운영	▣실 ▣부	○○○	*****	*****
4	기관운영	▤실 ▤부	○○○	*****	*****
5	기관운영	▥실 ▥부	○○○	*****	*****
6	기관운영	●실 ●부	○○○	*****	*****
7	사전점검	㉠지원 ㉠부	○○○	*****	*****
8	사전점검	㉡지원 ㉡부	○○○	*****	*****
9	사전점검	㉢지원 ㉢부	○○○	*****	*****
10	사전점검	㉣지원 ㉣부	○○○	*****	*****
11	사전점검	㉤실 ㉤부	○○○	*****	*****
12	사전점검	☆실 ☆부	○○○	*****	*****
13	사전점검	★실 ★부	○○○	*****	*****
14	의약품일련번호	●센터 ●부	○○○	*****	*****
15	의약품일련번호	●센터 ●부	○○○	*****	*****
16	의약품일련번호	●센터 ●부	○○○	*****	*****
17	의약품일련번호	●센터 ●부	○○○	*****	*****
18	의약품일련번호	◎실 ◎부	○○○	*****	*****

연번	정보통신시스템	소속	성명	개인계정	관리자계정
19	차세대 심사운영	◇실 ◇부	○○○	*****	*****
20	차세대 심사운영	◆◆파견	○○○	*****	*****
21	차세대 심사운영	◆지원 ◆부	○○○	*****	*****
22	차세대 심사운영	□지원 □부	○○○	*****	*****
23	차세대 심사운영	■실 ■부	○○○	*****	*****
24	차세대 심사운영	△실 △부	○○○	*****	*****
25	차세대 심사운영	△실 △부	○○○	*****	*****
26	차세대 심사운영	△실 △부	○○○	*****	*****
27	차세대 심사운영	▲실 ▲부	○○○	*****	*****
28	차세대 심사운영	▽지원 ▽부	○○○	*****	*****
29	차세대 심사운영	▼실 ▼부	○○○	*****	*****
30	차세대 심사운영	▼실 ▼부	○○○	*****	*****
31	차세대 심사운영	▼실 ▼부	○○○	*****	*****
32	차세대 심사운영	▼실 ▼부	○○○	*****	*****

【조치할 사항】

- 기획상임이사는 업무상으로 관리자 계정이 필요한 경우 별도의 승인 절차를 두는 등 보안 사고를 예방하기 위한 정보보안 방안을 마련하시기 바랍니다 (권고)